

Cyber Threat Intelligence

Executive Briefing

Report Date: July 17, 2026

Generated: 2026-07-17 12:47 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
5	12	3	0	20

2. Executive Summary

As of July 17, 2026, the security operations center has concluded an assessment of 20 identified vulnerabilities, categorized as 5 Critical, 12 High, and 3 Medium. The current organizational risk posture is evaluated as 'High,' driven primarily by exposure to remote code execution and service disruption vectors that threaten the integrity of our primary infrastructure. The highest priority threat is CVE-2026-50289, an OS Command Injection vulnerability in the SystemInformation Library, which represents an unacceptable risk of unauthorized system-level execution. Immediate mitigation requires the prioritization of patching efforts and the implementation of compensatory access controls. We maintain a posture of 'High Alert' until remediation of all critical findings is verified.

3. Critical Action List

- Execute an immediate patch deployment for CVE-2026-50289 within 24 hours to neutralize the OS Command Injection vector.
- Implement traffic filtering rules for CVE-2026-54466 to prevent message corruption within 24 hours.
- Force mandatory TLS validation protocols for all kumactl instances associated with CVE-2026-50166 within 48 hours.
- Restrict websocket-driver compression parameters to mitigate resource limit bypass vulnerabilities CVE-2026-54490 and CVE-2026-54464 within 48 hours.
- Initiate emergency patching for all 12 High-severity vulnerabilities, with full remediation to be completed within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-50289	OS Command Injection in SystemInf...	9.8	Critical	88/100	CWE-78

CVE-2026-54466	Message Corruption via Protocol H...	9.8	Critical	88/100	CWE-130
CVE-2026-50166	Insecure TLS Certificate Validati...	9.1	Critical	82/100	CWE-295
CVE-2026-54490	Resource Limit Bypass in Websocke...	9.1	Critical	82/100	CWE-770
CVE-2026-54464	Resource Limit Bypass via Message...	9.1	Critical	82/100	CWE-770
CVE-2026-54504	Unauthenticated Web UI API Exposu...	8.8	High	79/100	CWE-306
CVE-2026-54498	HTML-Safety Bypass in ViewCompone...	8.7	High	78/100	CWE-79
CVE-2026-50285	Memory Exhaustion in Pomerium HPK...	7.5	High	68/100	CWE-400
CVE-2026-50276	DoS in dd-trace-rb via W3C Baggag...	7.5	High	68/100	CWE-400
CVE-2026-50274	DoS in dd-trace-go via W3C Baggag...	7.5	High	68/100	CWE-400
CVE-2026-50273	DoS in dd-trace-dotnet via W3C Ba...	7.5	High	68/100	CWE-400
CVE-2026-50272	DoS in dd-trace-js via W3C Baggag...	7.5	High	68/100	CWE-400
CVE-2026-50271	DoS in dd-trace-py via W3C Baggag...	7.5	High	68/100	CWE-400
CVE-2026-50270	DoS in dd-trace-java via W3C Bagg...	7.5	High	68/100	CWE-400
CVE-2026-54465	Memory Exhaustion in Websocket-Dr...	7.5	High	68/100	CWE-400
CVE-2026-54463	Memory Exhaustion via Protocol He...	7.5	High	68/100	CWE-400
CVE-2026-54254	API Key Exposure via Third-Party ...	7.5	High	68/100	CWE-20
CVE-2026-54497	Stale Context Retention in ViewCo...	6.8	Medium	61/100	CWE-362
CVE-2026-58196	SSRF in ToolHive MCP Authenticati...	4.7	Medium	42/100	CWE-918
CVE-2026-54495	Cross-Namespace Exposure in Open-...	4.3	Medium	39/100	CWE-668

5. Detailed Vulnerability Findings

CVE-2026-50289

Finding: OS Command Injection in SystemInformation Library

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-78

Score Provenance: Tenable Verified

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The systeminformation library contains an OS command injection vulnerability in the networkInterfaces() method. The flaw arises from insecure concatenation of the 'interfaces(5)' source-directive path variable with shell commands executed on the underlying Linux host. An attacker can supply a malicious path string to execute arbitrary system commands with the privileges of the application process.

Proof of Concept (PoC):

A local attacker provides a malicious string as the interface source path input to the networkInterfaces() function. The library passes this unsanitized string into a system shell command executor. The shell interprets the embedded special characters as new commands to be run by the OS. The attacker gains execution of arbitrary code within the context of the running application.

```
**Technical Details:**
...

POST /vulnerable-endpoint HTTP/1.1
Host: target.com
Content-Type: application/x-www-form-urlencoded

param=value; id

**curl command:**
```bash
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"
```
```

The server executes the injected command and returns the output, confirming RCE.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50289>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50289>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50289>

CVE-2026-54466

Finding: Message Corruption via Protocol Header Abuse

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-130

Score Provenance: Tenable Verified
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | None | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | High |
| Integrity Impact | High | Availability Impact | High |

Description:

The websocket-driver library is vulnerable to message corruption due to improper processing of protocol length headers. The flaw exists because the parser fails to validate that the reported frame length matches the actual data payload received. An attacker can manipulate length headers to corrupt the frame sequence, potentially causing application crashes or inconsistent state processing.

Proof of Concept (PoC):

An unauthenticated attacker sends a series of WebSocket frames with maliciously constructed length headers that misalign the expected payload. The websocket-driver fails to reconcile the internal header pointers with the incoming buffer stream. The resulting memory corruption causes the application to process malformed data as valid commands.

This leads to severe system instability and potentially allows for code execution.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54466>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54466>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54466>

CVE-2026-50166

Finding: Insecure TLS Certificate Validation in Kumactl

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-295

Score Provenance: Tenable Verified
MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | None | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | High |
| Integrity Impact | High | Availability Impact | None |

Description:

The kumactl utility fails to implement mandatory TLS certificate verification when communicating with the control plane in the absence of a configured Certificate Authority. This vulnerability arises because the client-side connection logic defaults to an insecure state, ignoring certificate chain validation errors. An attacker performing a man-in-the-middle attack can intercept or manipulate control plane traffic, leading to full confidentiality and integrity loss for administrative communications.

Proof of Concept (PoC):

An attacker positioned between the kumactl client and the control plane initiates a malicious handshake. The attacker presents a self-signed or invalid certificate, which the client accepts due to the lack of CA enforcement. The client proceeds to transmit authentication tokens and configuration data over the compromised link. This enables the attacker to masquerade as the control plane and steal sensitive service mesh management credentials.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50166>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50166>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50166>

CVE-2026-54490

Finding: Resource Limit Bypass in Websocket-Driver Compression

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-770

Score Provenance: Tenable Verified
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | None | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | None |
| Integrity Impact | High | Availability Impact | High |

Description:

The websocket-driver library is vulnerable to a resource limit bypass when handling message compression. The parser does not enforce strict limits on decompressed frame sizes, allowing for excessive resource allocation. An attacker can send crafted compressed messages that expand to fill available server memory.

Proof of Concept (PoC):

An attacker initiates a WebSocket connection and sends a highly compressed message that requests massive expansion upon reaching the driver. The driver fails to validate the size of the uncompressed data before allocating memory buffers. This forces the server to allocate excessive memory, potentially impacting service availability. The resource exhaustion effectively bypasses intended service limits for WebSocket frames.

Technical Details:

```
***

An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.

curl command (conceptual):
bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
***
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54490>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54490>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54490>

CVE-2026-54464

Finding: Resource Limit Bypass via Message Compression

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-770

Score Provenance: Tenable Verified
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | None |
| Scope | Unchanged |
| Integrity Impact | High |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | None |
| Availability Impact | High |

Description:

The websocket-driver library is vulnerable to a resource limit bypass when handling message compression. The parser does not enforce strict limits on decompressed frame sizes, allowing for excessive resource allocation. An attacker can send crafted compressed messages that expand to fill available server memory.

Proof of Concept (PoC):

An attacker initiates a WebSocket connection and sends a highly compressed message that expands significantly upon reaching the driver. The driver fails to validate the total size of the uncompressed data relative to system resources. This forces the server to allocate excessive memory, potentially impacting service availability. The resource exhaustion effectively bypasses intended frame size controls.

****Technical Details:****

...

An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.

****curl command (conceptual):****

```
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54464>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54464>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54464>

CVE-2026-54504

Finding: Unauthenticated Web UI API Exposure in MCP Server

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-306

Score Provenance: Tenable Verified
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Adjacent | Attack Complexity | Low |
| Privileges Required | None | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | High |
| Integrity Impact | High | Availability Impact | High |

Description:

The @andrea9293/mcp-documentation-server's Web UI API binds to all network interfaces without requiring any form of authentication by default. The design oversight assumes that local access implies trust, failing to implement access controls for non-local connections. This permits any network-adjacent attacker to perform arbitrary administrative operations via the exposed API endpoints.

Proof of Concept (PoC):

An unauthenticated remote attacker scans the network to identify the documentation server service on its default port. The attacker sends an unauthorized HTTP request to the management API endpoint to modify server configuration settings. The server processes the request without verifying the requester's identity or authorization status. This results in total administrative compromise of the MCP documentation environment.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54504>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54504>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54504>

CVE-2026-54498

Finding: HTML-Safety Bypass in ViewComponent around _render

CVSS v3.1 Score: 8.7 | Severity: High | Urgency Score: 78/100 | CWE: CWE-79

Score Provenance: Tenable Verified

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:N

| | |
|---------------------|---------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Changed |
| Integrity Impact | High |

| | |
|------------------------|----------|
| Attack Complexity | Low |
| User Interaction | Required |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The ViewComponent around_render hook fails to properly sanitize output, leading to an HTML-Safety bypass and potential Cross-Site Scripting (XSS). The vulnerability exists because the framework improperly escapes content processed during the component's render wrapper. An attacker can inject malicious client-side scripts that are executed in the context of other users' browsers.

Proof of Concept (PoC):

An attacker crafts a malicious input string containing script tags and submits it to a vulnerable form field. The ViewComponent around_render logic fails to escape this input during processing. The server returns the unsanitized script to other users viewing the page. This leads to arbitrary script execution in the victims' browser sessions.

Technical Details:

...

```
GET /search?q=<img src=x onerror=alert(1)> HTTP/1.1
```

```
Host: target.com
```

...

curl command:

```
```bash
```

```
curl "https://target.com/search?q="
```

...

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54498>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54498>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54498>

## CVE-2026-50285

### Finding: Memory Exhaustion in Pomerium HPKE Callback

**CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400**

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Pomerium is vulnerable to a pre-authentication memory exhaustion attack due to unbounded zstd decompression in its HPKE callback processing. The lack of size constraints on the decompression buffer allows an attacker to allocate arbitrary amounts of server memory by sending a small, highly compressed payload. This results in a Denial of Service condition by crashing the process or exhausting available system resources.

Proof of Concept (PoC):

An unauthenticated attacker sends a specially crafted, highly compressed HPKE request to the Pomerium gateway. The server's zstd decompression routine blindly expands the input without checking against allocated memory limits. The uncontrolled memory consumption leads to an immediate service halt or system crash. This effectively shuts down authentication services for all users.

Technical Details:

An attacker sends a specially crafted input that triggers resource exhaustion. For example, a deeply nested structure or a massive list can consume CPU or memory.

curl command (conceptual):

```
bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50285>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50285>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50285>

CVE-2026-50276

Finding: DoS in dd-trace-rb via W3C Baggage Headers

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

The dd-trace-rb library improperly parses W3C baggage headers, leading to potential Denial of Service. The parsing logic fails to validate the depth and complexity of nested baggage entries, allowing for resource exhaustion. An attacker can send malicious headers to trigger excessive CPU or memory usage within the tracing middleware.

Proof of Concept (PoC):

An unauthenticated attacker sends a request containing a crafted 'baggage' header with deeply nested values to a monitored Ruby application. The dd-trace-rb middleware attempts to parse this complex header recursively without depth limits. This consumes excessive CPU cycles, causing the application thread to hang or crash. The service



becomes unavailable to legitimate requests due to resource saturation.

**Technical Details:**  
...

An attacker sends a specially crafted input that triggers resource exhaustion.  
For example, a deeply nested structure or a massive list can consume CPU or memory.

**curl command (conceptual):**  
...  
bash  
curl "https://target.com/vulnerable-endpoint?payload=<malicious\_input>"  
...

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50276>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50276>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50276>

## CVE-2026-50274

### Finding: DoS in dd-trace-go via W3C Baggage Headers

**CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400**

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1499

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

#### Description:

The dd-trace-go library improperly parses W3C baggage headers, leading to potential Denial of Service. The parsing logic fails to validate the depth and complexity of nested baggage entries, allowing for resource exhaustion. An attacker can send malicious headers to trigger excessive CPU or memory usage within the tracing middleware.

#### Proof of Concept (PoC):

An unauthenticated attacker sends a request containing a crafted 'baggage' header with deeply nested values to a monitored Go application. The dd-trace-go middleware attempts to parse this complex header recursively without depth limits. This consumes excessive CPU cycles, causing the application goroutines to block or crash. The service becomes unavailable to legitimate requests due to resource saturation.

**Technical Details:**  
...

An attacker sends a specially crafted input that triggers resource exhaustion.  
For example, a deeply nested structure or a massive list can consume CPU or memory.

**curl command (conceptual):**  
...  
bash  
curl "https://target.com/vulnerable-endpoint?payload=<malicious\_input>"  
...

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50274>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50274>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50274>

CVE-2026-50273

Finding: DoS in dd-trace-dotnet via W3C Baggage Headers

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

The dd-trace-dotnet library improperly parses W3C baggage headers, leading to potential Denial of Service. The parsing logic fails to validate the depth and complexity of nested baggage entries, allowing for resource exhaustion. An attacker can send malicious headers to trigger excessive CPU or memory usage within the tracing middleware.

Proof of Concept (PoC):

An unauthenticated attacker sends a request containing a crafted 'baggage' header with deeply nested values to a monitored .NET application. The dd-trace-dotnet middleware attempts to parse this complex header recursively without depth limits. This consumes excessive CPU cycles, causing the application threads to hang. The service becomes unavailable to legitimate requests due to resource saturation.

\*\*Technical Details:\*\*  
```

An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.

curl command (conceptual):
```bash  
curl "https://target.com/vulnerable-endpoint?payload=<malicious\_input>"  
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50273>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50273>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50273>

CVE-2026-50272

Finding: DoS in dd-trace-js via W3C Baggage Headers

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The dd-trace-js library improperly parses W3C baggage headers, leading to potential Denial of Service. The parsing logic fails to validate the depth and complexity of nested baggage entries, allowing for resource exhaustion. An attacker can send malicious headers to trigger excessive CPU or memory usage within the tracing middleware.

Proof of Concept (PoC):

An unauthenticated attacker sends a request containing a crafted 'baggage' header with deeply nested values to a monitored Node.js application. The dd-trace-js middleware attempts to parse this complex header recursively without depth limits. This consumes excessive CPU cycles, blocking the event loop. The service becomes unavailable to legitimate requests due to resource saturation.

Technical Details:

...

An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.

curl command (conceptual):

```
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50272>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50272>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50272>

CVE-2026-50271

Finding: DoS in dd-trace-py via W3C Baggage Headers

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | None |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | None |
| Availability Impact | High |

Description:

The dd-trace-py library improperly parses W3C baggage headers, leading to potential Denial of Service. The parsing logic fails to validate the depth and complexity of nested baggage entries, allowing for resource exhaustion. An attacker can send malicious headers to trigger excessive CPU or memory usage within the tracing middleware.

Proof of Concept (PoC):

An unauthenticated attacker sends a request containing a crafted 'baggage' header with deeply nested values to a monitored Python application. The dd-trace-py middleware attempts to parse this complex header recursively without depth limits. This consumes excessive CPU cycles, causing the application worker to hang. The service becomes unavailable to legitimate requests due to resource saturation.

Technical Details:

```
***
An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.
**curl command (conceptual):**
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
***
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50271>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50271>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50271>

CVE-2026-50270

Finding: DoS in dd-trace-java via W3C Baggage Headers

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | None | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | None |
| Integrity Impact | None | Availability Impact | High |

Description:

The dd-trace-java library improperly parses W3C baggage headers, leading to potential Denial of Service. The parsing logic fails to validate the depth and complexity of nested baggage entries, allowing for resource exhaustion. An attacker can send malicious headers to trigger excessive CPU or memory usage within the tracing middleware.

Proof of Concept (PoC):

An unauthenticated attacker sends a request containing a crafted 'baggage' header with deeply nested values to a monitored Java application. The dd-trace-java middleware attempts to parse this complex header recursively without depth limits. This consumes excessive CPU cycles, leading to thread starvation. The service becomes unavailable to legitimate requests due to resource saturation.

****Technical Details:****

...

An attacker sends a specially crafted input that triggers resource exhaustion. For example, a deeply nested structure or a massive list can consume CPU or memory.

****curl command (conceptual):****

```
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50270>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50270>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50270>

CVE-2026-54465

Finding: Memory Exhaustion in Websocket-Driver Parser

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Tenable Verified
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | None | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | None |
| Integrity Impact | None | Availability Impact | High |

Description:

The websocket-driver HTTP header parser is susceptible to memory exhaustion. The vulnerability is triggered by an unbounded processing of long or malformed header lines. An attacker can send extremely large headers to force the server to allocate excessive heap memory, leading to a service crash.

Proof of Concept (PoC):

An unauthenticated attacker sends a HTTP Upgrade request with an abnormally large header segment to the server. The websocket-driver's header parser attempts to buffer the entire header without enforcing a maximum size limit. This causes the process to consume nearly all available memory before crashing. The service is rendered inaccessible to legitimate users as a result.

****Technical Details:****

...

An attacker sends a specially crafted input that triggers resource exhaustion. For example, a deeply nested structure or a massive list can consume CPU or memory.

****curl command (conceptual):****

```
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54465>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54465>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54465>

CVE-2026-54463

Finding: Memory Exhaustion via Protocol Header Abuse

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Tenable Verified
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | None | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | None |
| Integrity Impact | None | Availability Impact | High |

Description:

The websocket-driver library is susceptible to memory exhaustion by abusing protocol length headers. The parser, when processing frames with large length fields, allocates memory buffers before verifying the existence of the corresponding data. An attacker can repeatedly send frames with high length values to trigger significant heap allocation and exhaustion.

Proof of Concept (PoC):

An unauthenticated attacker sends multiple WebSocket frames with extremely high values defined in the length header. The library attempts to allocate buffers matching the length values without confirming if the transport stream contains the full data. The server's memory consumption increases rapidly with each request. This results in the exhaustion of system resources and potential service degradation.

Technical Details:
...

An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.

curl command (conceptual):
...
bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
...

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54463>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54463>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54463>

CVE-2026-54254

Finding: API Key Exposure via Third-Party Sites

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: Tenable Verified
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

| | |
|---------------------|------------------|
| Attack Vector | Network |
| Privileges Required | None |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|-------------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The Pixeldrain API improperly leaks user API keys to unverified third-party sites. This vulnerability arises because the application does not validate the integrity of requests before including security tokens in outbound transmissions or external integration calls. An attacker can capture these credentials from the logs or traffic of the third-party platforms.

Proof of Concept (PoC):

An attacker registers as a user on an integrated third-party site associated with Pixeldrain. The Pixeldrain API sends the user's active API key to the third-party site as part of a default credential handshake. The attacker accesses the third-party site's logs or API interface to extract the plain-text credential. This results in full account compromise for the affected user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54254>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54254>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54254>

CVE-2026-54497**Finding: Stale Context Retention in ViewComponent**

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 61/100 | CWE: CWE-362

Score Provenance: Tenable Verified

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:N

| | |
|---------------------|------------------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | High |

| | |
|------------------------|-------------|
| Attack Complexity | High |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The ViewComponent library fails to properly clear render context, causing reused component instances to retain state from previous rendering cycles. This race condition occurs because the component lifecycle management does not enforce state isolation between concurrent requests. An attacker may leverage this to view data intended for other users during subsequent rendering cycles.

Proof of Concept (PoC):

An attacker makes concurrent requests to a web application utilizing ViewComponent with specific rendering configurations. Due to the lack of proper context clearing, a component instance servicing one request captures data from the other request's context. The attacker observes the leaked state in the final HTML output. This results in unauthorized disclosure of sensitive user information.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54497>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54497>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54497>

CVE-2026-58196

Finding: SSRF in ToolHive MCP Authentication Discovery

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-918

Score Provenance: Tenable Verified

MITRE ATT&CK: T1046

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:N/A:N

| | |
|---------------------|---------|
| Attack Vector | Network |
| Privileges Required | None |
| Scope | Changed |
| Integrity Impact | None |

| | |
|------------------------|----------|
| Attack Complexity | Low |
| User Interaction | Required |
| Confidentiality Impact | Low |
| Availability Impact | None |

Description:

The ToolHive remote MCP server authentication discovery mechanism is susceptible to Server-Side Request Forgery. This flaw exists because the discovery handler fails to validate or restrict destination hostnames provided during the handshake process. An attacker can leverage this to bypass container isolation and reach internal network services that would otherwise be unreachable from the external environment.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an MCP authentication discovery request to the ToolHive gateway with a malicious 'host' parameter targeting an internal metadata service. The server fails to sanitize the input and initiates an outbound connection to the specified internal IP address. The server returns the result of the internal request back to the attacker, facilitating reconnaissance of sensitive infrastructure.

Technical Details:

...

GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1

Host: target.com

...

curl command:

```bash

curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"

...

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-58196>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-58196>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-58196>

CVE-2026-54495

Finding: Cross-Namespace Exposure in Open-Feature Operator

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-668

Score Provenance: Estimated (Unverified) - Vector Recalculated



MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

|                     |           |                        |      |
|---------------------|-----------|------------------------|------|
| Attack Vector       | Network   | Attack Complexity      | Low  |
| Privileges Required | Low       | User Interaction       | None |
| Scope               | Unchanged | Confidentiality Impact | Low  |
| Integrity Impact    | None      | Availability Impact    | None |

Description:

The open-feature-operator exposes sensitive FeatureFlagSource and InProcessConfiguration contents across namespaces in multi-tenant Kubernetes clusters. The defect stems from insufficient authorization checks during the resolution process, allowing configuration to leak regardless of namespace boundaries. This enables an attacker to gain visibility into configuration specifications they are not authorized to access.

Proof of Concept (PoC):

An authenticated user with low privileges in a tenant namespace sends a request to the operator to resolve a feature flag configuration located in a different, protected namespace. The operator fails to validate if the user has permission to access the cross-namespace resource. The system returns the full configuration specification, including sensitive flag details. This exposes private cluster configurations to unauthorized users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54495>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54495>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54495>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>

- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>